

Project-CYBERSECURITY POLICY AND INCIDENT RESPONSE PLAN FOR A SMALL BUSINESS

Submitted By

Name: Anushka

Course: B.tech CS-CS(5TH SEMESTER)

Academic Session: 2024-28

DECLARATION

I hereby declare that the project report titled “**Cybersecurity Policy and Incident Response Plan for ABC Retail Solutions**” is my own work and has been prepared as part of my academic project.

The work presented in this report has been carried out for educational purposes. The cybersecurity assessments, simulated incidents, network monitoring activities, and related demonstrations described in this project were performed in a controlled environment.

I have made sincere efforts to ensure that the information presented in this report is accurate and properly organized. Wherever information or resources from other sources have been used, they have been appropriately acknowledged.

Name: Anushka

Course/Program: B.tech CS-CS

Institution: GNIOT

Date: 01-09-26

ACKNOWLEDGEMENT

I would like to express my sincere gratitude to everyone who supported me during the completion of my project titled **“Cybersecurity Policy and Incident Response Plan for ABC Retail Solutions.”**

First, I would like to thank my project guide for providing valuable guidance, suggestions, and feedback throughout the project. Their support helped me understand the different concepts involved in cybersecurity, risk assessment, vulnerability assessment, security monitoring, and incident response.

I am also thankful to my teachers and department for providing me with the opportunity to work on this project and for giving me the resources and knowledge needed to complete it.

I would also like to thank my classmates and friends who helped me with discussions, ideas, and feedback during the development of the project.

Finally, I am grateful to my family for their constant support, encouragement, and patience throughout the completion of this work.

This project has helped me gain a better understanding of how cybersecurity policies, technical security controls, monitoring, and incident response can work together to protect a small business.

ABSTRACT

In today's digital world, businesses depend heavily on computers, networks, email, websites, cloud services, and databases for their daily activities. Because of this, cybersecurity has become an important part of running a business. Small businesses can be more vulnerable to cyberattacks because they may have limited resources, fewer security professionals, and a lack of proper security procedures. Common threats include phishing, malware, ransomware, unauthorized access, password attacks, and data theft.

This project, **“Cybersecurity Policy and Incident Response Plan for a Small Business,”** focuses on creating a simple and practical security framework for a fictional small business, ABC Retail Solutions. The project first identifies the important assets of the business and the possible threats that could affect them. A basic risk assessment is then carried out to understand which threats could have the greatest impact.

The project also develops cybersecurity policies related to password security, access control, email usage, data protection, device security, and backups. Along with these policies, an Incident Response Plan is created to explain what the organization should do when a cyber incident occurs.

For the practical part of the project, a phishing and account-compromise incident is simulated. The response process includes detecting the incident, investigating it, containing the threat, removing the cause, recovering affected systems, and identifying lessons learned. The project aims to show how even a small business can follow basic cybersecurity practices and have a clear plan for dealing with cyber incidents.

1.1 Background

Cybersecurity is the process of protecting computers, networks, applications, and important data from threats such as unauthorized access, damage, theft, and disruption. With the increasing use of technology, cybersecurity has become an important part of almost every business.

Today, businesses depend on computers, email, websites, cloud services, databases, and online applications to carry out their daily work. While these technologies make business operations easier and faster, they also create opportunities for cyberattacks. Small businesses can be especially at risk because they may have limited budgets, fewer cybersecurity experts, and less developed security procedures.

Some common cyber threats faced by businesses include phishing, malware, ransomware, password attacks, unauthorized access, social engineering, and data theft. A successful cyberattack can cause financial losses, interrupt normal business operations, expose sensitive information, and damage the reputation of the organization.

A cybersecurity policy helps a business set clear rules for protecting its systems, data, and employees. On the other hand, an incident response plan explains what steps should be taken when a cybersecurity incident occurs. It helps the organization detect the problem, control the situation, recover affected systems, and learn from the incident.

This project combines both cybersecurity policies and an incident response plan to develop a simple and practical security framework for a small business. The aim is to show how proper planning and basic security practices can help a small organization reduce cyber risks and respond effectively to security incidents.

1.2 Problem Statement

Small businesses today depend on digital systems for storing information, communicating with customers, handling transactions, and managing their daily activities. However, many small businesses may not have proper cybersecurity policies, strong access controls, or enough employee awareness about cyber threats. This can make their systems more vulnerable to attacks such as phishing, malware, unauthorized access, and data theft.

Another major problem is that small businesses may not have a proper plan for dealing with a cybersecurity incident. When an attack occurs, employees may not know whom to inform, which systems should be disconnected, how the incident should be investigated, or how the affected systems should be safely restored.

Therefore, this project aims to develop a simple and practical cybersecurity policy and incident response plan for a small business. The plan will help the organization reduce common cybersecurity risks, detect incidents at an early stage, respond to them in an organized manner, minimize their impact, and recover normal business operations effectively.

1.3 Objectives

The main objectives of this project are:

1. To identify important information assets of a small business.
2. To identify common cybersecurity threats and vulnerabilities.
3. To perform a basic cybersecurity risk assessment.
4. To develop appropriate cybersecurity policies for employees and systems.
5. To establish roles and responsibilities for incident response.
6. To develop a structured incident response procedure.
7. To simulate a phishing and account-compromise incident.
8. To demonstrate incident detection, containment, eradication, and recovery.
9. To identify lessons learned from the simulated incident.
10. To recommend measures for improving the organization's cybersecurity posture.

1.4 Scope

This project focuses on developing a cybersecurity policy and incident response plan for a fictional small business named ABC Retail Solutions.

The project covers asset identification, threat identification, risk assessment, password security, access control, email security, data protection, device security, backup procedures, incident classification, incident response roles, incident handling, recovery, and post-incident analysis.

A simulated phishing and account-compromise scenario is used for the practical demonstration. The simulation is performed for academic purposes and does not involve unauthorized access to real systems, networks, websites, or user accounts.

CHAPTER 2

COMPANY PROFILE

2.1 Organization Overview

For this project, a fictional small business named **ABC Retail Solutions** has been selected as a case study. The company works in the retail sector and uses computers, internet services, email, websites, and cloud applications for its regular business activities.

The company has around 25 employees who use computers and other digital systems to communicate with customers, manage business records, process sales, and perform their daily tasks. The company also maintains a customer database and a website to support its business operations.

Since a large part of the company's work depends on digital technology, protecting its systems and information is very important. A cyberattack such as phishing, malware, unauthorized access, or data theft could interrupt the company's work and may also put important business or customer information at risk.

This company has been selected for the project to understand the cybersecurity challenges that a small business may face and to develop suitable security policies and an incident response plan to deal with those challenges.

2.2 Business Activities

ABC Retail Solutions carries out several activities using its digital systems. These include:

- Managing customer information and records.
- Processing sales and other business transactions.
- Communicating with customers through email and the company website.
- Maintaining employee records.
- Storing important business documents.
- Using cloud services to store and share files.
- Managing inventory and sales information.
- Providing support to customers.

Since most of these activities involve computers or online services, any security problem could affect the normal working of the business.

2.3 IT Infrastructure

ABC Retail Solutions has a small IT setup that includes computers, a server, networking devices, internet connectivity, and cloud services. These systems help employees perform their everyday work.

The main components of the company's IT infrastructure are:

Component	Quantity	Purpose
Desktop/Laptop Computers	15	Used by employees for daily work
Server	1	Stores and manages important business data
Router	1	Provides internet and network connectivity
Network Switch	1	Connects devices within the network
Wi-Fi Access Point	1	Provides wireless network access
Network Printer	1	Used for printing business documents
Company Website	1	Provides information and communication to customers
Email Accounts	25	Used for business communication
Cloud Storage	1	Used to store and share files
Backup Storage	1	Used to keep copies of important data

2.4 Employees and Users

The company has around 25 employees, and each employee has different responsibilities. Because of this, not every employee needs access to all company systems and information.

For example, a regular employee may only need access to email, shared files, and the applications required for their work. On the other hand, the IT administrator may need additional access to the server, network devices, and security systems.

To reduce the chances of unauthorized access, employees should only be given the permissions they actually need to perform their jobs. This approach is known as the **principle of least privilege**.

2.5 Important Business Assets

The company depends on several important digital and physical assets. Some of the most important assets are listed below:

Asset	Description	Importance
Customer Database	Stores customer-related information	Critical
Server	Stores important business information	Critical
Employee Computers	Used for daily business activities	High
Email Accounts	Used for communication	High
Company Website	Represents the business online	High
Cloud Storage	Stores and shares business documents	High
Wi-Fi Network	Provides network access to employees	High
Backup Data	Helps recover lost or damaged information	Critical

These assets need to be properly protected because their loss, damage, or unauthorized access could affect the company's business operations.

2.6 Network Architecture

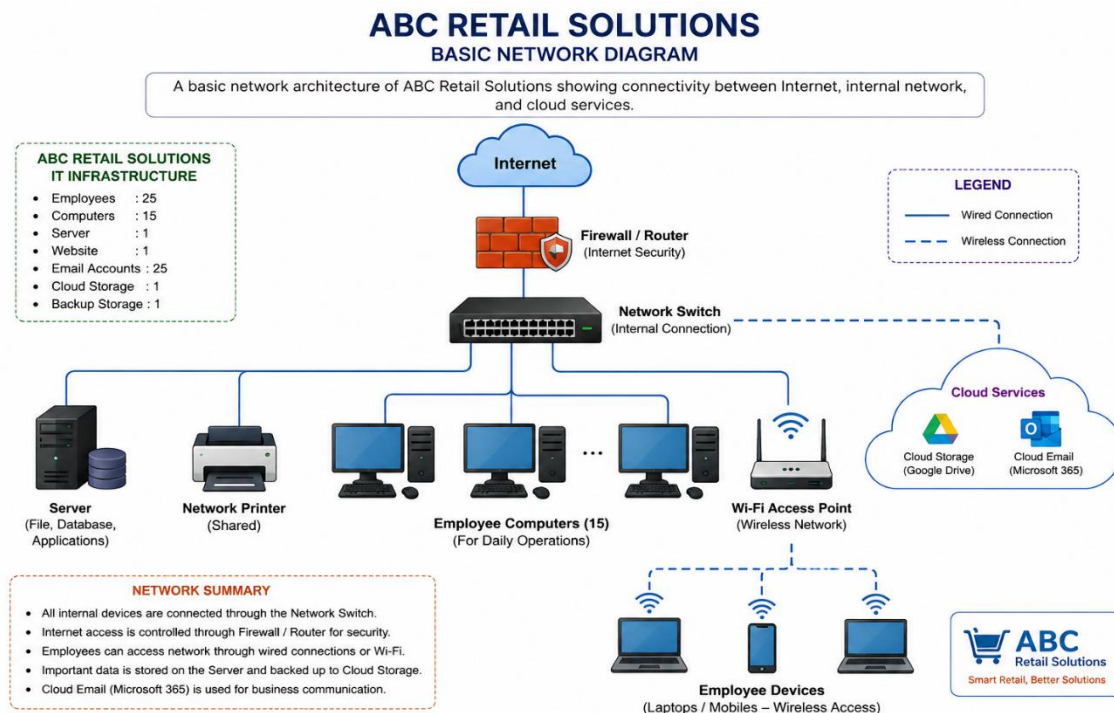
ABC Retail Solutions uses a basic network to connect its computers, server, printer, and other devices. The internet connection passes through a firewall and router before reaching the company's internal network.

The main network structure can be represented as:

Internet → Firewall/Router → Network Switch → Computers / Server / Printer

Employees can also connect to the network through Wi-Fi. Cloud services are accessed through the internet.

Figure 2.1: Basic Network Architecture of ABC



Retail Solutions

The network provides the basic connectivity required for the company's daily activities. However, security measures such as firewalls, strong passwords, access restrictions, antivirus software, regular software updates, and backups are necessary to keep the network and its data secure.

2.7 Need for Cybersecurity

Cybersecurity is important for ABC Retail Solutions because the company relies on digital systems for many of its daily activities. Without proper security measures, the company could become an easy target for cybercriminals.

A cyberattack could lead to problems such as:

- Loss or theft of customer information.
- Unauthorized access to company accounts.
- Malware infection on employee computers.

- Interruption of normal business activities.
- Financial losses.
- Loss of important business data.
- Damage to the company's reputation.

For these reasons, ABC Retail Solutions needs clear cybersecurity policies and a proper incident response plan. These measures can help employees understand how to protect company resources and also provide clear steps to follow if a cybersecurity incident occurs.

CHAPTER 3

ASSET IDENTIFICATION AND RISK ASSESSMENT

3.1 Introduction

Before securing a business from cyber threats, the first step is to understand what needs to be protected. A business has different types of assets, such as computers, servers, data, user accounts, websites, and network devices. Some assets are more important than others, so they require more attention and protection.

For **ABC Retail Solutions**, digital systems are an important part of the company's daily work. The company uses computers, a server, customer information, email accounts, a website, Wi-Fi, cloud storage, and backup systems. If any of these assets are damaged, lost, or accessed without permission, it could affect the company's normal operations.

A risk assessment helps the company identify possible threats and understand how likely they are to occur and how much damage they could cause. This makes it easier for the company to decide which risks need to be addressed first.

3.2 Asset Identification

The first step in the risk assessment is to identify the important assets of ABC Retail Solutions. These are the systems and information that the company depends on for its daily activities.

Asset	Description	Importance
Customer Database	Stores customer information and records	Critical
Server	Stores important business data and applications	Critical
Employee Computers	Used by employees for their daily work	High
Email Accounts	Used for communication with customers and employees	High
Company Website	Provides information about the business to customers	High
Cloud Storage	Used to store and share business files	High
Wi-Fi Network	Provides wireless access to the company network	High

Asset	Description	Importance
Backup Data	Helps recover important information if it is lost or damaged	Critical
Network Printer	Used for printing business documents	Medium
Router/Firewall	Manages network traffic and provides basic network security	Critical

These assets are important to the company, so protecting them is necessary to keep the business running smoothly.

3.3 Threat Identification

A threat is anything that can potentially harm a computer system, network, or data. Like any other business, ABC Retail Solutions could face different types of cybersecurity threats.

1. Phishing

Phishing is one of the most common cyber threats. In a phishing attack, an attacker sends a fake email or message to trick a person into clicking a harmful link or sharing sensitive information. For example, an attacker might pretend to be a bank, company, or trusted service.

2. Malware

Malware is harmful software that can affect computers and other devices. It may damage files, steal information, or allow someone to access a system without permission. Malware can enter a computer through suspicious downloads, websites, or email attachments.

3. Ransomware

Ransomware is a type of malware that can lock or encrypt files and prevent users from accessing them. If important business files are affected, the company may not be able to continue its normal activities until the problem is resolved.

4. Password Attacks

Using weak or reused passwords can make accounts easier to compromise. If an attacker gets an employee's password, they may be able to access company accounts, files, or other services.

5. Unauthorized Access

Unauthorized access occurs when someone gets access to a system, account, or network without permission. This could allow the person to view, change, or steal important company information.

6. Data Theft

Customer and business information is valuable and needs to be protected. If an attacker gains access to this information, it could result in financial losses and damage the company's reputation.

7. Social Engineering

Social engineering involves manipulating people into revealing information or performing an action that creates a security risk. Attackers may use trust, urgency, or fear to convince employees to make mistakes.

8. Network Attacks

The company's network can also be targeted by attackers. Poorly secured network devices or Wi-Fi can increase the chances of unauthorized access or disruption of network services.

3.4 Vulnerabilities

A vulnerability is a weakness in a system, process, or security practice that could be used by an attacker. Some possible vulnerabilities in ABC Retail Solutions are:

- Weak or reused passwords.
- Lack of multi-factor authentication (MFA).
- Outdated software and operating systems.
- Limited employee awareness about cybersecurity.
- Poor access controls.
- Inadequate backup practices.
- Unsecured computers and other devices.
- Limited monitoring of security events.
- Improper handling of sensitive information.
- Lack of a formal incident response procedure.

Identifying these weaknesses helps the company understand where improvements are needed.

3.5 Risk Assessment

After identifying the important assets, threats, and vulnerabilities, the next step is to find out which risks are more serious.

For this project, the risk score is calculated using the following formula:

$$\text{Risk Score} = \text{Likelihood} \times \text{Impact}$$

Both likelihood and impact are given a score from **1 to 5**. A higher score means that the risk needs more attention.

Likelihood Scale

Score Meaning

- | | |
|---|-----------|
| 1 | Very Low |
| 2 | Low |
| 3 | Medium |
| 4 | High |
| 5 | Very High |

Impact Scale

Score Meaning

- | | |
|---|-----------|
| 1 | Very Low |
| 2 | Low |
| 3 | Medium |
| 4 | High |
| 5 | Very High |

3.6 Risk Assessment Table

After considering the threats that could affect ABC Retail Solutions, the following risk assessment was prepared:

Threat	Likelihood	Impact	Risk Score	Risk Level
Phishing	5	5	25	Critical
Ransomware	3	5	15	High
Password Attack	4	4	16	Critical
Data Theft	3	5	15	High
Malware	3	4	12	High
Unauthorized Access	3	4	12	High
Social Engineering	4	4	16	Critical
Network Attack	2	4	8	Medium

From the table, phishing has the highest risk score of **25**, making it a critical risk for the company. Password attacks and social engineering are also critical risks, with scores of **16**.

These threats are important because they can directly target employees and may lead to stolen credentials, unauthorized access, or loss of important information.

3.7 Risk Classification

The risk scores are divided into four levels:

Risk Score Risk Level

1–5 Low

6–10 Medium

11–15 High

16–25 Critical

Risks classified as **Critical** should be given the highest priority because they have a greater possibility of causing serious problems for the business.

3.8 Risk Mitigation

After identifying the risks, ABC Retail Solutions needs to take appropriate steps to reduce them. The following measures can help the company improve its security:

Risk	Suggested Security Measure
Phishing	Employee awareness training and email filtering
Ransomware	Regular backups and endpoint protection
Password Attacks	Strong passwords and MFA
Data Theft	Access controls and encryption
Malware	Antivirus and regular software updates
Unauthorized Access	Least-privilege access and regular access reviews
Social Engineering	Employee training and verification procedures
Network Attacks	Firewall, secure Wi-Fi, and network monitoring

These measures can reduce the chances of an attack and also help limit the damage if an incident takes place.

3.9 Risk Assessment Summary

The risk assessment shows that ABC Retail Solutions can face several cybersecurity threats. The major risks are related to employee awareness, account security, sensitive information, and network protection.

Among the identified threats, **phishing** has been selected for the practical incident simulation in this project. It is a suitable scenario because phishing can start with a simple email and may eventually result in an employee account being compromised.

The findings from this risk assessment will be used in the next chapter to create cybersecurity policies for ABC Retail Solutions. These policies will focus on areas such as password security, access control, email security, data protection, device security, and backup management.

CHAPTER 4

CYBERSECURITY POLICY

4.1 Introduction

A cybersecurity policy is basically a set of rules that explains how a company should protect its computers, networks, data, and online accounts. It also helps employees understand how they are expected to use company systems safely.

For a small business like **ABC Retail Solutions**, having clear security rules is important. A small mistake, such as clicking a suspicious link, downloading an unsafe file, or sharing a password, can sometimes lead to a serious security problem.

Based on the risks identified in Chapter 3, this chapter describes the main cybersecurity policies recommended for ABC Retail Solutions. These policies are intended to protect the company's information, reduce common security risks, and help employees develop safer working habits.

4.2 Password Policy

Passwords are one of the simplest ways to protect company accounts. However, weak, reused, or easily guessed passwords can make it much easier for attackers to gain access.

ABC Retail Solutions should follow these basic password rules:

- Employees should create strong passwords that are difficult to guess.
- Passwords must not be shared with other employees.
- The same password should not be reused for important company accounts.
- Personal information such as names, birthdays, or phone numbers should not be used as passwords.
- Multi-factor authentication (MFA) should be enabled wherever it is available.
- If an employee believes that their password has been exposed, it should be changed immediately.
- Passwords should not be written down or left where other people can easily see them.

- A trusted password manager can be used to store passwords securely.

Following these rules can reduce the chances of someone gaining unauthorized access to company accounts.

4.3 Access Control Policy

Access control is used to decide which employees can access particular systems and information. Not every employee needs access to everything, so access should be provided according to their job responsibilities.

ABC Retail Solutions should follow these rules:

- Employees should only receive the access they need to do their jobs.
- Administrator privileges should be given only to authorized IT staff.
- Employees should use their own accounts and should not share accounts.
- User permissions should be reviewed regularly.
- Accounts belonging to employees who leave the company should be disabled as soon as possible.
- Sensitive information should only be available to authorized employees.
- Any unusual or unauthorized access should be reported to the IT administrator.

This approach follows the **principle of least privilege**, which helps limit the possible damage if an account is compromised.

4.4 Email Security Policy

Email is an important part of the company's daily communication, but it is also one of the common ways attackers try to target employees. Phishing emails, fake attachments, and suspicious links can all create security problems.

Employees at ABC Retail Solutions should:

- Avoid clicking links in suspicious or unexpected emails.
- Avoid opening attachments from unknown or untrusted senders.
- Check the sender's email address carefully before replying.
- Be careful with emails that create urgency or ask for confidential information.

- Verify unexpected payment or account-related requests through another trusted method.
- Report suspicious emails to the IT or security team.
- Never share passwords or other sensitive information through email without first verifying the request.

These simple practices can greatly reduce the chances of a successful phishing attack.

4.5 Data Protection Policy

ABC Retail Solutions handles customer and business information on a regular basis. This information should be protected from unauthorized access, accidental loss, and improper sharing.

The company should follow these rules:

- Sensitive information should only be accessible to employees who need it.
- Important files should be stored using approved company systems.
- Customer information should not be copied to personal devices without permission.
- Sensitive data should be protected when it is stored or transferred.
- Important information should be backed up regularly.
- Lost devices or accidental data exposure should be reported immediately.
- Company information should not be shared with unauthorized people.

These practices can help prevent the loss or accidental exposure of important information.

4.6 Device Security Policy

Employee computers and other devices are directly connected to the company's work environment, which makes them an important part of its security. If one device becomes infected or compromised, it could potentially affect other systems.

To reduce this risk, the company should ensure that:

- Antivirus or endpoint protection is installed and kept active.

- Operating systems and applications are updated regularly.
- Firewalls are enabled where required.
- Employees use secure passwords or other approved authentication methods.
- Computers are locked whenever they are left unattended.
- Employees do not install unauthorized software.
- Unknown USB devices should not be connected to company computers.
- Lost or stolen company devices must be reported immediately.

These measures help protect devices against malware, unauthorized access, and other common threats.

4.7 Wi-Fi and Network Security Policy

The company network connects employees to important systems and services, so it needs to be protected from unauthorized users.

ABC Retail Solutions should follow these practices:

- The company Wi-Fi should have a strong password.
- Default passwords on routers and other network devices should be changed.
- Secure wireless settings should be used.
- Guest Wi-Fi should be kept separate from the company's internal network.
- Only authorized employees should have access to the internal network.
- Network devices should be updated when security updates are available.
- Any unusual network activity should be reported to the IT administrator.

These measures can make it more difficult for unauthorized users to access the company's network.

4.8 Backup Policy

Backups are important because they give the company a way to recover its information if files are accidentally deleted, damaged, or affected by malware or ransomware.

ABC Retail Solutions should:

- Back up important business information regularly.
- Keep multiple copies of important data.
- Store at least one backup separately from the main systems.
- Limit access to backup data.
- Test backups regularly to make sure the data can actually be restored.
- Protect backups from unauthorized changes or deletion.

Where possible, the company should follow the **3-2-1 backup approach**:

3 copies of important data → 2 different types of storage → 1 copy stored separately.

Having reliable backups can make recovery much easier after a serious security incident.

4.9 Software Update and Patch Policy

Software developers regularly release updates to fix bugs and security weaknesses. If these updates are ignored, attackers may be able to take advantage of known vulnerabilities.

ABC Retail Solutions should:

- Keep operating systems up to date.
- Install important security updates as soon as reasonably possible.
- Regularly update browsers and commonly used applications.
- Remove software that is no longer needed.
- Keep network devices updated where applicable.
- Regularly check company systems for missing security updates.

Keeping software updated is a simple but effective way to reduce security risks.

4.10 Employee Security Awareness Policy

Employees are an important part of the company's cybersecurity. Even when technical security measures are in place, a simple human mistake can sometimes create an opportunity for an attacker.

ABC Retail Solutions should provide regular cybersecurity awareness training covering topics such as:

- How to recognize phishing emails.
- How to create and protect strong passwords.
- Why MFA should be used.
- Safe internet and email practices.
- How to handle company information.
- How and when to report suspicious activity.
- Safe use of company computers and mobile devices.
- How to recognize common social engineering techniques.

Employees should also feel comfortable reporting mistakes or suspicious activity without being afraid of immediately being blamed. Reporting a problem early gives the company a better chance of dealing with it before it becomes more serious.

4.11 Acceptable Use Policy

Company computers, internet connections, email accounts, and other IT resources are provided mainly for business-related activities. Employees are expected to use these resources responsibly.

Employees should:

- Use company systems responsibly and appropriately.
- Avoid unsafe or suspicious websites.
- Not download or install unauthorized software.
- Not share company accounts with other people.
- Not use company systems for illegal activities.
- Not try to bypass or disable security controls.
- Take reasonable care when accessing company information while working remotely.

Following these rules helps keep the company's systems safe and reduces unnecessary security risks.

4.12 Incident Reporting Policy

Employees should report a cybersecurity problem as soon as they notice something unusual. Quick reporting can help the company investigate the problem and reduce its possible impact.

Examples of incidents that should be reported include:

- Suspicious emails or messages.
- Accidentally clicking a suspicious link.
- Lost or stolen company devices.
- Unexpected login or password-change notifications.
- Suspected malware infections.
- Unauthorized access to an account or system.
- Accidental sharing of sensitive information.
- Unusual computer or network activity.

When reporting an incident, employees should provide basic details such as what happened, when it happened, and which computer, account, or system was involved. They should also avoid deleting or changing possible evidence unless instructed by the IT or security team.

Early reporting is an important part of the company's overall incident response process.

CHAPTER 5

VULNERABILITY ASSESSMENT

5.1 Introduction

A vulnerability assessment is carried out to find weaknesses in an organization's systems, devices, applications, and security practices. Finding these weaknesses early gives the organization an opportunity to fix them before they become a serious security problem.

For **ABC Retail Solutions**, the assessment focuses on the company's computers, server, network, Wi-Fi, email accounts, website, and backup systems. Employee practices are also considered because human mistakes can sometimes create security risks.

The main purpose of this assessment is not to attack the company's systems, but to identify possible weaknesses and suggest practical ways to improve security.

5.2 Objectives of Vulnerability Assessment

The main objectives of carrying out the vulnerability assessment are:

- To find possible weaknesses in the company's IT environment.
- To identify which assets are more exposed to security threats.
- To understand the possible effect of each vulnerability.
- To decide which vulnerabilities should be fixed first.
- To suggest suitable security measures.
- To improve the overall security of the organization.

5.3 Scope of the Assessment

The assessment covers the main systems and security areas used by ABC Retail Solutions.

Area	Included
Employee Computers	Yes
Server	Yes
Network Devices	Yes

Area	Included
Wi-Fi Network	Yes
Email Accounts	Yes
Company Website	Yes
Cloud Storage	Yes
Backup System	Yes
Employee Security Practices	Yes

The assessment is based on the fictional environment created for this project. No real organization's systems, accounts, or networks are tested.

5.4 Vulnerability Identification

After looking at the company's infrastructure and the risks identified in the previous chapter, several possible vulnerabilities were identified.

V01 – Weak Passwords

If employees use weak or reused passwords, their accounts may be easier for attackers to compromise.

Risk: An attacker could gain unauthorized access to company accounts.

Recommended solution: Use strong passwords, a password manager, and multi-factor authentication (MFA).

V02 – Lack of Multi-Factor Authentication

If an account is protected only by a password, an attacker who obtains that password may be able to access the account.

Risk: Stolen credentials could lead to unauthorized access.

Recommended solution: Enable MFA for email accounts, cloud services, administrator accounts, and other important systems.

V03 – Outdated Software

Software that is not regularly updated may contain known security weaknesses.

Risk: Attackers could take advantage of these weaknesses to gain access or cause damage.

Recommended solution: Keep operating systems and applications updated and follow a regular patching process.

V04 – Excessive User Permissions

Giving employees more access than they need can create additional security risks.

Risk: If an employee's account is compromised, the attacker could potentially access files or systems that are not required for that employee's job.

Recommended solution: Follow the principle of least privilege and review user permissions regularly.

V05 – Insecure Wi-Fi Configuration

A weak Wi-Fi password or poor wireless security settings could allow unauthorized people to connect to the company network.

Risk: An unauthorized user may gain access to internal network resources.

Recommended solution: Use strong Wi-Fi security, strong passwords, and a separate guest network.

V06 – Insufficient Backup Protection

Backups are not very useful if they are not protected or tested regularly.

Risk: The company may have difficulty recovering important data after ransomware, accidental deletion, or system failure.

Recommended solution: Follow the 3-2-1 backup approach and regularly test whether backups can be restored.

V07 – Limited Security Logging

If important system and network activities are not properly recorded, it can be difficult to notice suspicious behavior.

Risk: An attacker could remain undetected for a longer period.

Recommended solution: Enable suitable system and network logging and centralize important logs where possible.

V08 – Lack of Employee Security Awareness

Employees who are not familiar with phishing and social engineering may accidentally create security problems.

Risk: An employee could click a malicious link, open an unsafe attachment, or share sensitive information.

Recommended solution: Provide regular cybersecurity awareness training and conduct safe simulated phishing exercises.

5.5 Vulnerability Assessment Table

The vulnerabilities identified during the assessment are summarized below:

ID	Asset/Area	Vulnerability	Severity	Recommended Solution
V01	Employee Accounts	Weak or reused passwords	High	Strong passwords + MFA
V02	Email/Cloud Accounts	No MFA	Critical	Enable MFA
V03	Computers/Server	Outdated software	High	Regular patching
V04	User Accounts	Excessive permissions	High	Least privilege
V05	Wi-Fi	Weak configuration	High	Secure Wi-Fi + guest network
V06	Backup	Backup not regularly tested	High	Regular backup and recovery testing
V07	Network/Systems	Limited logging	Medium	Centralized logging
V08	Employees	Low security awareness	High	Regular security training

From the table, the lack of MFA is considered a **critical vulnerability**, while weak passwords, outdated software, excessive permissions, insecure Wi-Fi, backup issues, and low security awareness are considered high-risk areas.

5.6 Vulnerability Severity Classification

The vulnerabilities are grouped into four levels depending on how serious they could be for the organization.

Severity	Description
Critical	Could cause major damage or serious unauthorized access
High	Could have a significant effect on systems, data, or business operations
Medium	Could create a security problem but may require additional conditions
Low	Has limited impact and can usually be managed easily

Critical and high-severity vulnerabilities should be handled first because they could have a greater effect on the organization.

5.7 Vulnerability Prioritization

After reviewing the identified vulnerabilities, the following areas should receive the highest priority.

Priority 1 – Lack of MFA

MFA should be introduced for important accounts so that a stolen password alone is not enough to access the account.

Priority 2 – Weak Passwords

The company should introduce strong password rules and discourage password reuse, especially for important business accounts.

Priority 3 – Outdated Software

Operating systems, applications, and network devices should be checked regularly and updated when security updates are available.

Priority 4 – Excessive Permissions

User permissions should be reviewed to make sure employees only have access to the systems and information they actually need.

Priority 5 – Employee Awareness

Employees should receive regular training so they can recognize phishing emails, suspicious messages, and other social engineering attempts.

5.8 Vulnerability Remediation Plan

Once vulnerabilities have been identified, the company needs a clear plan for fixing them.

Priority	Vulnerability	Action	Responsible Person	Target
1	No MFA	Enable MFA	IT Administrator	Immediate
2	Weak Passwords	Implement password policy	IT + Management	Immediate
3	Outdated Software	Apply security updates	IT Administrator	Regularly
4	Excessive Access	Review user permissions	IT Administrator	Monthly
5	Weak Wi-Fi	Improve wireless security	IT Administrator	Immediate
6	Backup Issues	Test backup restoration	IT Administrator	Monthly
7	Limited Logging	Enable centralized logging	IT/Security Team	Planned
8	Low Awareness	Conduct security training	Management/HR	Quarterly

This remediation plan gives the company a clear idea of what needs to be fixed, who is responsible for it, and how often the work should be carried out.

5.9 Verification and Reassessment

Fixing a vulnerability is only part of the process. The company should also check whether the recommended security measures are actually working.

For example, after MFA is enabled, the IT administrator should verify that it has been activated for all important accounts. Similarly, after installing software updates, the systems should be checked to make sure they are properly updated.

The vulnerability assessment should also be repeated from time to time. New software, devices, employees, and business processes can introduce new security weaknesses, so security needs to be reviewed regularly.

5.10 Vulnerability Assessment Summary

The assessment identified several areas that could create security problems for ABC Retail Solutions. The main areas of concern are account security, outdated software, access control, Wi-Fi security, backups, logging, and employee awareness.

The assessment also shows that cybersecurity is not only about installing antivirus software or a firewall. Good security also depends on proper policies, regular updates, controlled access, employee awareness, reliable backups, and continuous monitoring.

The vulnerabilities identified in this chapter will be used in the next stages of the project to improve the company's security controls and incident response process. In particular, **MFA, phishing awareness, and security monitoring** will be important because they can help reduce the risk of account compromise.

The next stage of the project will focus on **security monitoring and log analysis**, followed by the development and practical demonstration of the Incident Response Plan.

CHAPTER 6

SECURITY MONITORING AND LOG ANALYSIS

6.1 Introduction

Identifying and fixing vulnerabilities is important, but it is not enough to keep a business secure. The organization also needs to regularly monitor its systems and network to notice any unusual activity. Security monitoring helps in finding possible security incidents at an early stage.

For **ABC Retail Solutions**, monitoring can be used to keep track of activities taking place on employee computers, the server, network devices, Wi-Fi, and other important systems. These systems generate logs that contain useful information about activities such as logins, network connections, and system events.

Logs are especially useful during a security investigation because they can help answer basic questions such as **what happened, when it happened, and which system or account was involved**.

In this project, **Zeek** is considered for network monitoring, while the **ELK Stack**, consisting of Elasticsearch, Logstash, and Kibana, can be used for collecting, storing, searching, and visualizing logs.

The main goal of security monitoring is to notice unusual activity early and provide useful information for investigating a possible incident.

6.2 Importance of Security Monitoring

Security monitoring helps ABC Retail Solutions keep track of what is happening on its systems and network. It can help the company notice activity that may otherwise go unnoticed.

Some examples of activity that can be monitored are:

- Multiple failed login attempts.
- Unexpected successful logins.
- Unusual network connections.
- Large or unexpected amounts of network traffic.
- Suspicious DNS requests.

- Repeated access attempts.
- Unusual activity from a particular device.
- Other events that may require investigation.

Monitoring is also useful after an incident because the collected logs can help the security team understand what happened and how the incident should be handled.

6.3 Sources of Security Logs

Different systems used by ABC Retail Solutions can generate different types of logs. Some important sources are:

Log Source	Information That Can Be Collected
Employee Computers	Login events, system activity, application events
Server	User activity, system events, and service activity
Firewall	Allowed and blocked network connections
Router	Network connection information
Wi-Fi	Device connections and authentication activity
Email System	Login and email-related activity
Website	Requests, errors, and access information
Zeek	Network connections, DNS, HTTP, and other network events

Collecting information from different sources gives the security team a better overall view of what is happening in the environment.

6.4 Network Monitoring Using Zeek

Zeek is a network security monitoring tool that can observe network traffic and create useful logs from it. Instead of looking at every individual packet, Zeek provides information about network activities in an easier-to-analyze format.

For this project, Zeek can be used in a controlled lab environment to observe normal network activity and generate logs for analysis.

The basic process is:

Network Traffic



Zeek



Zeek Logs



Log Analysis



Identify Unusual Activity

Some useful Zeek logs include:

- **conn.log** – provides information about network connections.
- **dns.log** – records DNS-related activity.
- **http.log** – records HTTP activity where applicable.
- **notice.log** – contains notices generated by Zeek.

These logs can help the security team understand the type of network activity taking place.

6.5 Log Collection Using ELK

For a more advanced monitoring setup, ABC Retail Solutions can use the **ELK Stack**.

ELK consists of three main components:

Elasticsearch

Elasticsearch is used to store and search collected log information.

Logstash

Logstash can receive logs, process them, and send them to Elasticsearch.

Kibana

Kibana provides dashboards and visualizations that make the collected information easier to understand.

The overall process can be represented as:

Network / System Logs



Logstash



Elasticsearch



Kibana



Security Dashboard

Using this setup, security-related information from different sources can be viewed and analyzed from a central location.

6.6 Security Monitoring Dashboard

A security dashboard can provide a quick overview of important events in the organization.

For ABC Retail Solutions, the dashboard could display information such as:

Dashboard Section	Example Information
--------------------------	----------------------------

Total Events	Total number of collected events
--------------	----------------------------------

Failed Logins	Number of unsuccessful login attempts
---------------	---------------------------------------

Successful Logins	Number of successful login attempts
-------------------	-------------------------------------

Network Connections	Number of observed connections
---------------------	--------------------------------

DNS Requests	Number of DNS queries
--------------	-----------------------

Security Alerts	Number of events requiring investigation
-----------------	--

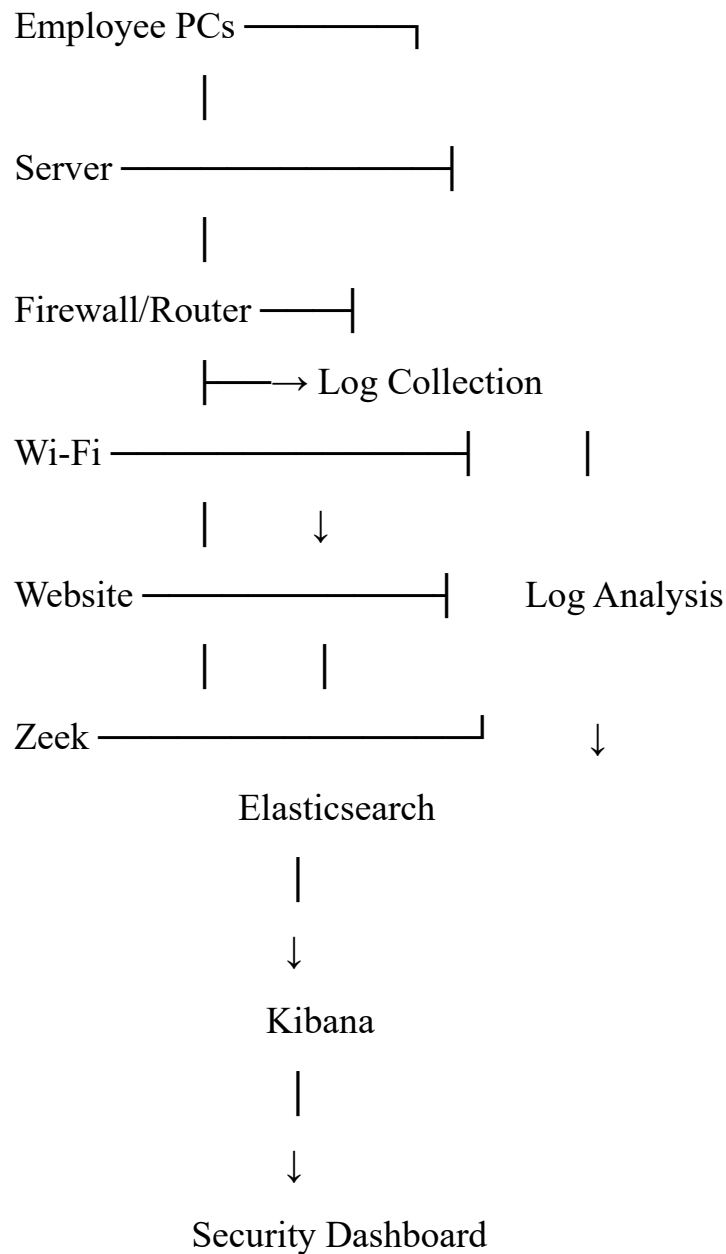
Top Source IPs	Devices producing the most activity
----------------	-------------------------------------

Dashboard Section Example Information

Event Timeline Security events over a period of time

A dashboard makes it easier for the IT or security team to notice unusual patterns without having to manually go through every log.

Figure 6.1: Security Monitoring Architecture



6.7 Log Analysis

Log analysis means reviewing recorded events and looking for activity that appears unusual or requires further investigation.

For example, consider the following **simulated login records**:

Time	User	Event	Result
------	------	-------	--------

09:45	employee01	Login	Failed
-------	------------	-------	--------

09:46	employee01	Login	Failed
-------	------------	-------	--------

09:47	employee01	Login	Failed
-------	------------	-------	--------

09:48	employee01	Login	Failed
-------	------------	-------	--------

09:49	employee01	Login	Failed
-------	------------	-------	--------

09:51	employee01	Login	Successful
-------	------------	-------	------------

Five failed login attempts followed shortly by a successful login could be considered suspicious and may require further investigation.

The security team could check:

- Whether the employee was actually trying to log in.
- Where the login attempts came from.
- Which device was involved.
- Whether the login time was normal.
- Whether similar activity occurred on other accounts.
- Whether there were any other suspicious events around the same time.

The example above uses **simulated data for academic purposes** and does not represent actual company activity.

6.8 Basic Security Detection Rules

Security monitoring becomes more useful when certain conditions can automatically generate alerts.

Rule 1 – Multiple Failed Logins

IF

5 or more failed login attempts

occur within 10 minutes

THEN

Generate a security alert

This rule can help identify possible password attacks or other suspicious login activity.

Rule 2 – Failed Logins Followed by Success

IF

multiple failed login attempts
are followed by a successful login

THEN

Flag the account for investigation

This does not automatically mean that an account has been compromised. It simply tells the security team that the activity deserves a closer look.

Rule 3 – Unusual Network Activity

IF

a device suddenly creates an unusually
large number of network connections

THEN

Generate an alert for investigation

The exact threshold would depend on the organization's normal network activity.

6.9 Connection Between Monitoring and Incident Response

Security monitoring and incident response work together. Monitoring helps identify something unusual, while the incident response process explains what should happen next.

The process can be represented as:

Security Monitoring



Suspicious Activity Detected



Security Alert



Investigation



Is It a Security Incident?



YES



Incident Response Plan

For example, if unusual login activity is detected, the security team can investigate the account. If the activity is confirmed as unauthorized, the Incident Response Plan can be activated.

6.10 Phishing Incident and Monitoring

The phishing scenario selected for this project can also be connected to security monitoring.

The complete sequence can be represented as:

Phishing Email



Employee Clicks Suspicious Link



Credentials May Be Compromised



Unusual Login Activity



Security Alert



Investigation



Incident Response

The monitoring system may not directly identify the phishing email. Instead, unusual activity that happens after the phishing attempt, such as an unexpected login, may provide a warning that the account needs to be investigated.

This shows why monitoring is an important part of the overall cybersecurity process.

6.11 Benefits of Centralized Monitoring

Centralized monitoring can provide several benefits to ABC Retail Solutions:

- Important security events can be viewed in one place.
- Investigations can be performed more easily.
- Suspicious activity can be identified faster.
- Logs from different systems can be compared.
- Dashboards can make large amounts of information easier to understand.
- Historical logs can be useful during investigations.
- Alerts can be created for specific types of suspicious activity.

However, access to logs should be restricted to authorized personnel, and the logs themselves should be protected from unauthorized modification.

6.12 Limitations of Security Monitoring

Although monitoring is useful, it cannot detect or prevent every possible cyberattack.

Some limitations include:

- Not every attack produces an obvious warning.
- Missing or incomplete logs can make an investigation difficult.
- Too many alerts can make it difficult to identify important events.
- Logs need to be stored securely.
- Someone needs to review important alerts.
- Incorrectly configured monitoring can generate false alerts.

Because of these limitations, monitoring should be used together with other security measures such as strong authentication, access control, employee training, backups, and an incident response plan.

6.13 Chapter Summary

Security monitoring gives ABC Retail Solutions a way to keep track of important activity on its systems and network. The logs collected from different sources can help the company identify unusual activity and investigate security incidents.

In this project, **Zeek** can be used to observe network activity and generate useful network logs. The **ELK Stack** can then be used to collect, store, search, and visualize logs through a security dashboard.

Simple detection rules, such as identifying repeated failed logins, can help bring suspicious activity to the attention of the security team.

The monitoring process creates a link between **detecting suspicious activity and starting the Incident Response Plan**. The next chapter will focus on the Incident Response Plan and explain how ABC Retail Solutions should handle a confirmed cybersecurity incident.

CHAPTER 6

SECURITY MONITORING AND LOG ANALYSIS

6.1 Introduction

Identifying and fixing vulnerabilities is important, but it is not enough to keep a business secure. The organization also needs to regularly monitor its systems and network to notice any unusual activity. Security monitoring helps in finding possible security incidents at an early stage.

For **ABC Retail Solutions**, monitoring can be used to keep track of activities taking place on employee computers, the server, network devices, Wi-Fi, and other important systems. These systems generate logs that contain useful information about activities such as logins, network connections, and system events.

Logs are especially useful during a security investigation because they can help answer basic questions such as **what happened, when it happened, and which system or account was involved**.

In this project, **Zeek** is considered for network monitoring, while the **ELK Stack**, consisting of Elasticsearch, Logstash, and Kibana, can be used for collecting, storing, searching, and visualizing logs.

The main goal of security monitoring is to notice unusual activity early and provide useful information for investigating a possible incident.

6.2 Importance of Security Monitoring

Security monitoring helps ABC Retail Solutions keep track of what is happening on its systems and network. It can help the company notice activity that may otherwise go unnoticed.

Some examples of activity that can be monitored are:

- Multiple failed login attempts.
- Unexpected successful logins.
- Unusual network connections.
- Large or unexpected amounts of network traffic.
- Suspicious DNS requests.

- Repeated access attempts.
- Unusual activity from a particular device.
- Other events that may require investigation.

Monitoring is also useful after an incident because the collected logs can help the security team understand what happened and how the incident should be handled.

6.3 Sources of Security Logs

Different systems used by ABC Retail Solutions can generate different types of logs. Some important sources are:

Log Source	Information That Can Be Collected
Employee Computers	Login events, system activity, application events
Server	User activity, system events, and service activity
Firewall	Allowed and blocked network connections
Router	Network connection information
Wi-Fi	Device connections and authentication activity
Email System	Login and email-related activity
Website	Requests, errors, and access information
Zeek	Network connections, DNS, HTTP, and other network events

Collecting information from different sources gives the security team a better overall view of what is happening in the environment.

6.4 Network Monitoring Using Zeek

Zeek is a network security monitoring tool that can observe network traffic and create useful logs from it. Instead of looking at every individual packet, Zeek provides information about network activities in an easier-to-analyze format.

For this project, Zeek can be used in a controlled lab environment to observe normal network activity and generate logs for analysis.

The basic process is:

Network Traffic



Zeek



Zeek Logs



Log Analysis



Identify Unusual Activity

Some useful Zeek logs include:

- **conn.log** – provides information about network connections.
- **dns.log** – records DNS-related activity.
- **http.log** – records HTTP activity where applicable.
- **notice.log** – contains notices generated by Zeek.

These logs can help the security team understand the type of network activity taking place.

6.5 Log Collection Using ELK

For a more advanced monitoring setup, ABC Retail Solutions can use the **ELK Stack**.

ELK consists of three main components:

Elasticsearch

Elasticsearch is used to store and search collected log information.

Logstash

Logstash can receive logs, process them, and send them to Elasticsearch.

Kibana

Kibana provides dashboards and visualizations that make the collected information easier to understand.

The overall process can be represented as:

Network / System Logs



Logstash



Elasticsearch



Kibana



Security Dashboard

Using this setup, security-related information from different sources can be viewed and analyzed from a central location.

6.6 Security Monitoring Dashboard

A security dashboard can provide a quick overview of important events in the organization.

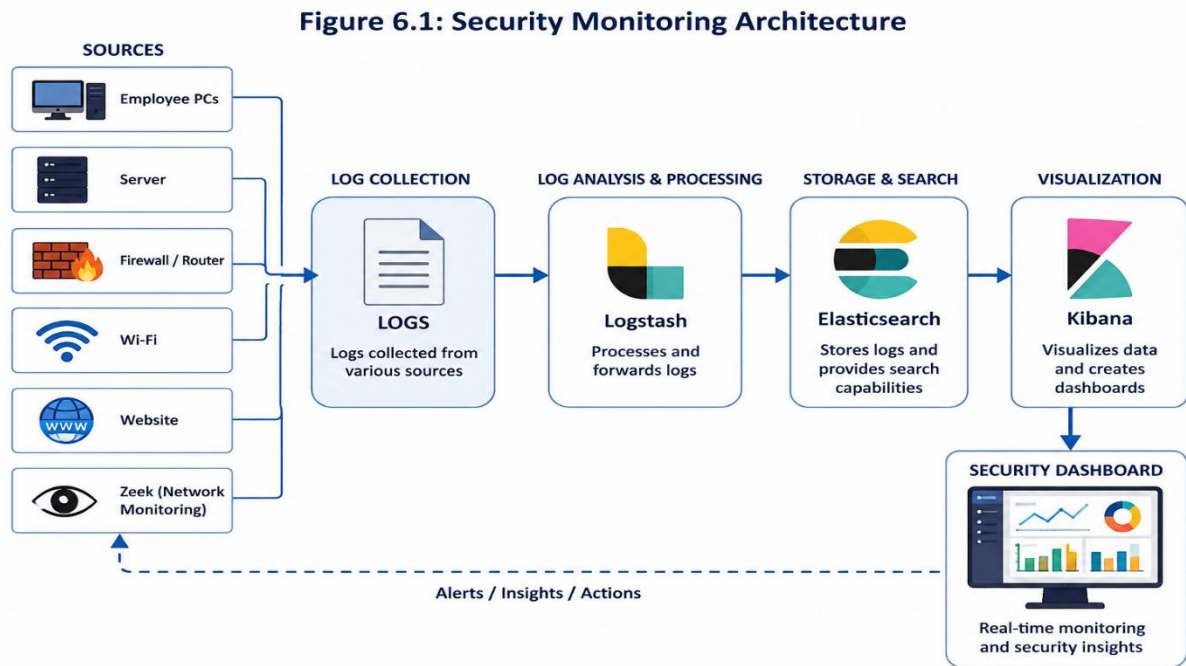
For ABC Retail Solutions, the dashboard could display information such as:

Dashboard Section	Example Information
Total Events	Total number of collected events
Failed Logins	Number of unsuccessful login attempts
Successful Logins	Number of successful login attempts
Network Connections	Number of observed connections
DNS Requests	Number of DNS queries
Security Alerts	Number of events requiring investigation
Top Source IPs	Devices producing the most activity

Dashboard Section	Example Information
Event Timeline	Security events over a period of time

A dashboard makes it easier for the IT or security team to notice unusual patterns without having to manually go through every log.

Figure 6.1: Security Monitoring Architecture



6.7 Log Analysis

Log analysis means reviewing recorded events and looking for activity that appears unusual or requires further investigation.

For example, consider the following **simulated login records**:

Time	User	Event	Result
09:45	employee01	Login	Failed
09:46	employee01	Login	Failed
09:47	employee01	Login	Failed
09:48	employee01	Login	Failed
09:49	employee01	Login	Failed

Time	User	Event	Result
09:51	employee01	Login	Successful

Five failed login attempts followed shortly by a successful login could be considered suspicious and may require further investigation.

The security team could check:

- Whether the employee was actually trying to log in.
- Where the login attempts came from.
- Which device was involved.
- Whether the login time was normal.
- Whether similar activity occurred on other accounts.
- Whether there were any other suspicious events around the same time.

The example above uses **simulated data for academic purposes** and does not represent actual company activity.

6.8 Basic Security Detection Rules

Security monitoring becomes more useful when certain conditions can automatically generate alerts.

Rule 1 – Multiple Failed Logins

IF

5 or more failed login attempts

occur within 10 minutes

THEN

Generate a security alert

This rule can help identify possible password attacks or other suspicious login activity.

Rule 2 – Failed Logins Followed by Success

IF

multiple failed login attempts
are followed by a successful login

THEN

Flag the account for investigation

This does not automatically mean that an account has been compromised. It simply tells the security team that the activity deserves a closer look.

Rule 3 – Unusual Network Activity

IF

a device suddenly creates an unusually
large number of network connections

THEN

Generate an alert for investigation

The exact threshold would depend on the organization's normal network activity.

6.9 Connection Between Monitoring and Incident Response

Security monitoring and incident response work together. Monitoring helps identify something unusual, while the incident response process explains what should happen next.

The process can be represented as:

Security Monitoring



Suspicious Activity Detected



Security Alert



Investigation



Is It a Security Incident?



YES



Incident Response Plan

For example, if unusual login activity is detected, the security team can investigate the account. If the activity is confirmed as unauthorized, the Incident Response Plan can be activated.

6.10 Phishing Incident and Monitoring

The phishing scenario selected for this project can also be connected to security monitoring.

The complete sequence can be represented as:

Phishing Email



Employee Clicks Suspicious Link



Credentials May Be Compromised



Unusual Login Activity



Security Alert



Investigation



Incident Response

The monitoring system may not directly identify the phishing email. Instead, unusual activity that happens after the phishing attempt, such as an unexpected login, may provide a warning that the account needs to be investigated.

This shows why monitoring is an important part of the overall cybersecurity process.

6.11 Benefits of Centralized Monitoring

Centralized monitoring can provide several benefits to ABC Retail Solutions:

- Important security events can be viewed in one place.
- Investigations can be performed more easily.
- Suspicious activity can be identified faster.
- Logs from different systems can be compared.
- Dashboards can make large amounts of information easier to understand.
- Historical logs can be useful during investigations.
- Alerts can be created for specific types of suspicious activity.

However, access to logs should be restricted to authorized personnel, and the logs themselves should be protected from unauthorized modification.

6.12 Limitations of Security Monitoring

Although monitoring is useful, it cannot detect or prevent every possible cyberattack.

Some limitations include:

- Not every attack produces an obvious warning.
- Missing or incomplete logs can make an investigation difficult.
- Too many alerts can make it difficult to identify important events.
- Logs need to be stored securely.
- Someone needs to review important alerts.
- Incorrectly configured monitoring can generate false alerts.

Because of these limitations, monitoring should be used together with other security measures such as strong authentication, access control, employee training, backups, and an incident response plan.

6.13 Chapter Summary

Security monitoring gives ABC Retail Solutions a way to keep track of important activity on its systems and network. The logs collected from different sources can help the company identify unusual activity and investigate security incidents.

In this project, **Zeek** can be used to observe network activity and generate useful network logs. The **ELK Stack** can then be used to collect, store, search, and visualize logs through a security dashboard.

Simple detection rules, such as identifying repeated failed logins, can help bring suspicious activity to the attention of the security team.

The monitoring process creates a link between **detecting suspicious activity and starting the Incident Response Plan**. The next chapter will focus on the Incident Response Plan and explain how ABC Retail Solutions should handle a confirmed cybersecurity incident.

CHAPTER 7

INCIDENT RESPONSE PLAN

7.1 Introduction

Even after taking different security measures, a business can still experience a cyberattack or security incident. For this reason, it is important to have a clear plan that explains what to do when an incident occurs.

An **Incident Response Plan (IRP)** provides a step-by-step approach for handling cybersecurity incidents. It helps the organization understand who is responsible for responding, what actions should be taken, and how affected systems should be brought back to normal.

For **ABC Retail Solutions**, the Incident Response Plan covers common situations such as phishing, malware, ransomware, unauthorized access, data leakage, and suspicious network activity.

The plan is also connected to the security monitoring process discussed in Chapter 6. When suspicious activity is detected through logs, alerts, or an employee report, the Incident Response Plan helps the company decide what to do next.

7.2 Objectives of the Incident Response Plan

The main purpose of the Incident Response Plan is to help the company handle security incidents in an organized way.

The objectives are:

- Detect security incidents as early as possible.
- Reduce the damage caused by an incident.
- Clearly define who is responsible for handling the incident.
- Stop the incident from spreading to other systems.
- Remove the cause of the incident.
- Restore affected systems safely.
- Keep a proper record of what happened.
- Learn from the incident and improve security in the future.

7.3 Types of Incidents Covered

ABC Retail Solutions may face different types of cybersecurity incidents. The main incidents covered by this plan are:

Incident	Example
Phishing	An employee clicks a suspicious email link
Malware	Malicious software is detected on a computer
Ransomware	Important company files are encrypted
Unauthorized Access	Someone gains access to an account without permission
Data Leakage	Sensitive information is accidentally exposed
Password Attack	An account receives repeated failed login attempts
Lost Device	A company laptop or mobile device is lost
Network Attack	Suspicious activity is detected on the network

The response will depend on the type of incident and how seriously it affects the company.

7.4 Incident Response Team

Since ABC Retail Solutions is a small business, it does not need a large dedicated security team. Instead, responsibilities can be divided among existing employees.

Role	Responsibility
Business Manager	Makes important business decisions during serious incidents
IT Administrator	Handles technical investigation and system recovery
Security Coordinator	Coordinates the overall response
HR Representative	Handles employee-related matters
Legal Advisor	Provides advice when legal or regulatory issues are involved

Role	Responsibility
Communication Officer	Handles communication when customers, employees, or other parties need to be informed

In a small incident, one person may handle more than one responsibility. If the incident is serious, the company can also seek help from an external cybersecurity professional.

7.5 Incident Severity Levels

Not every security event is equally serious. ABC Retail Solutions can classify incidents into four levels.

Level 1 – Low

A minor event that has little or no effect on normal business operations.

Example: An employee receives a suspicious email but does not click any link or open an attachment.

Response: Report the email, investigate it, remove or block it, and record the event.

Level 2 – Medium

An incident that affects one user or device but has limited impact on the business.

Example: An employee downloads a suspicious file.

Response: Isolate the affected device, investigate the file, remove the threat, and monitor the device.

Level 3 – High

An incident where an important account or system may have been compromised.

Example: Unusual login activity is detected on an employee's account.

Response: Secure or disable the account, investigate the logs, reset the password, verify MFA, and check for additional suspicious activity.

Level 4 – Critical

A serious incident that affects several systems, sensitive information, or important business operations.

Example: Ransomware affects multiple company computers.

Response: Activate the full incident response process, isolate affected systems, preserve relevant evidence, investigate the incident, and recover systems using clean backups.

7.6 Incident Response Lifecycle

The incident response process used by ABC Retail Solutions consists of seven main stages:

Preparation



Detection



Analysis



Containment



Eradication



Recovery



Lessons Learned

Each stage has a different purpose and helps the company deal with an incident in an organized manner.

7.7 Phase 1 – Preparation

Preparation takes place before an incident happens. The goal is to make sure the company is ready to respond when a security problem occurs.

ABC Retail Solutions should:

- Keep the Incident Response Plan updated.
- Assign responsibilities to employees.
- Maintain important contact information.

- Keep regular backups of important data.
- Keep security software updated.
- Enable appropriate system and network logging.
- Provide cybersecurity awareness training.
- Review security policies regularly.
- Conduct occasional incident response exercises.

Good preparation can save valuable time during an actual incident.

7.8 Phase 2 – Detection and Reporting

The next step is to identify that something unusual may have happened.

A security incident can be noticed through:

- An employee reporting suspicious activity.
- Security alerts.
- Firewall logs.
- Login or authentication logs.
- Server logs.
- Email security systems.
- Network monitoring.
- Zeek logs.
- ELK/Kibana dashboards.

For example, several failed login attempts followed by a successful login could be considered suspicious. However, this does not automatically mean that the account has been compromised. The activity should first be investigated.

Once an incident is suspected, it should be reported to the IT Administrator or Security Coordinator.

7.9 Phase 3 – Analysis

After a possible incident is detected, the next step is to understand what actually happened.

The security team should try to find answers to questions such as:

- What happened?
- When did it happen?
- Which user or device was involved?
- Which systems were affected?
- How did the incident start?
- Is the suspicious activity still happening?
- Could any sensitive information have been affected?

Logs from computers, servers, network devices, email systems, and monitoring tools can be useful during this stage.

Important information should be recorded carefully, and relevant evidence should not be deleted or changed unnecessarily.

7.10 Phase 4 – Containment

Containment means taking action to stop the incident from spreading or causing additional damage.

Depending on the situation, the company may:

- Disconnect an affected computer from the network.
- Temporarily disable a compromised account.
- Revoke active login sessions.
- Block suspicious network connections.
- Restrict access to affected systems.
- Separate an affected device from other systems.

For example, if an employee's account is suspected of being compromised, the account can be temporarily disabled while the investigation is carried out.

The main goal is to control the incident while avoiding unnecessary disruption to other business activities.

7.11 Phase 5 – Eradication

Once the incident has been contained, the company needs to remove the cause of the problem.

This may involve:

- Removing malicious software.
- Deleting malicious emails.
- Resetting compromised passwords.
- Removing unauthorized accounts or access.
- Installing missing security updates.
- Fixing the vulnerability that allowed the incident to happen.
- Checking other systems for similar signs of compromise.

Affected systems should be checked properly before they are returned to normal use.

7.12 Phase 6 – Recovery

After the threat has been removed, the company can begin restoring normal operations.

Recovery may include:

- Restoring files from clean backups.
- Reconnecting secured devices to the network.
- Restoring user access.
- Checking that systems are working correctly.
- Monitoring systems for additional suspicious activity.
- Confirming that security controls are working properly.

The company should continue monitoring the affected systems for some time after recovery to make sure the problem has not returned.

7.13 Phase 7 – Lessons Learned

The final stage is to look back at the incident and understand what could be improved.

The company should consider questions such as:

- What caused the incident?
- How was it detected?
- How long did it take to respond?
- Which security measures worked?
- What difficulties occurred during the response?
- Could the incident have been prevented?
- What should be changed in the future?

The findings can then be used to improve security policies, employee training, monitoring, and technical controls.

7.14 Incident Communication

Communication is important during a cybersecurity incident, but information should only be shared with people who actually need to know.

The company should decide:

- Who needs to be informed.
- What information should be shared.
- Who will communicate the information.
- When management should be contacted.
- When legal advice may be required.
- Whether customers or other affected parties need to be informed.

Employees should not publicly discuss an ongoing incident or share information that has not been verified.

7.15 Evidence and Documentation

Keeping proper records during an incident is important because it helps the company understand what happened and what actions were taken.

The incident record should contain:

- Incident ID.
- Date and time of detection.

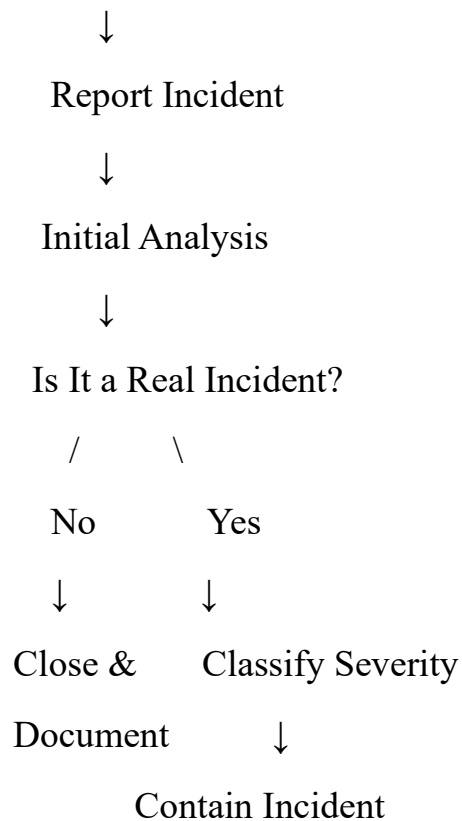
- Name or role of the person who reported it.
- Affected user or system.
- Type and severity of the incident.
- Relevant log information.
- Actions taken.
- People involved in the response.
- Recovery actions.
- Final outcome.
- Lessons learned.

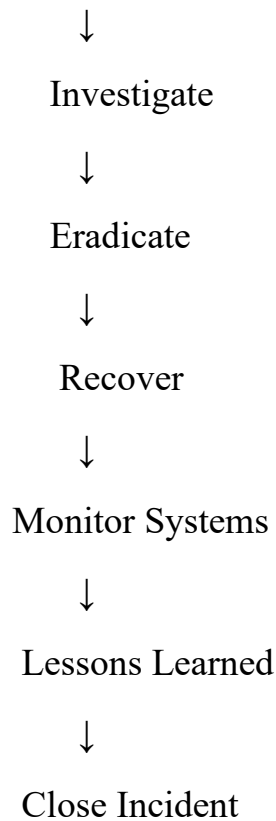
Relevant logs and other evidence should be preserved whenever possible so they can be reviewed later.

7.16 Incident Response Decision Flow

The following flow can be followed when suspicious activity is detected:

Suspicious Activity Detected





This gives employees and the IT team a clear idea of what to do instead of making decisions randomly during a stressful situation.

7.17 Phishing Incident Response

Phishing was identified as one of the highest risks in Chapter 3, so it has been selected as the main practical incident scenario for this project.

The response process can be represented as:

Phishing Email Received



Employee Reports Email



Security Team Investigates

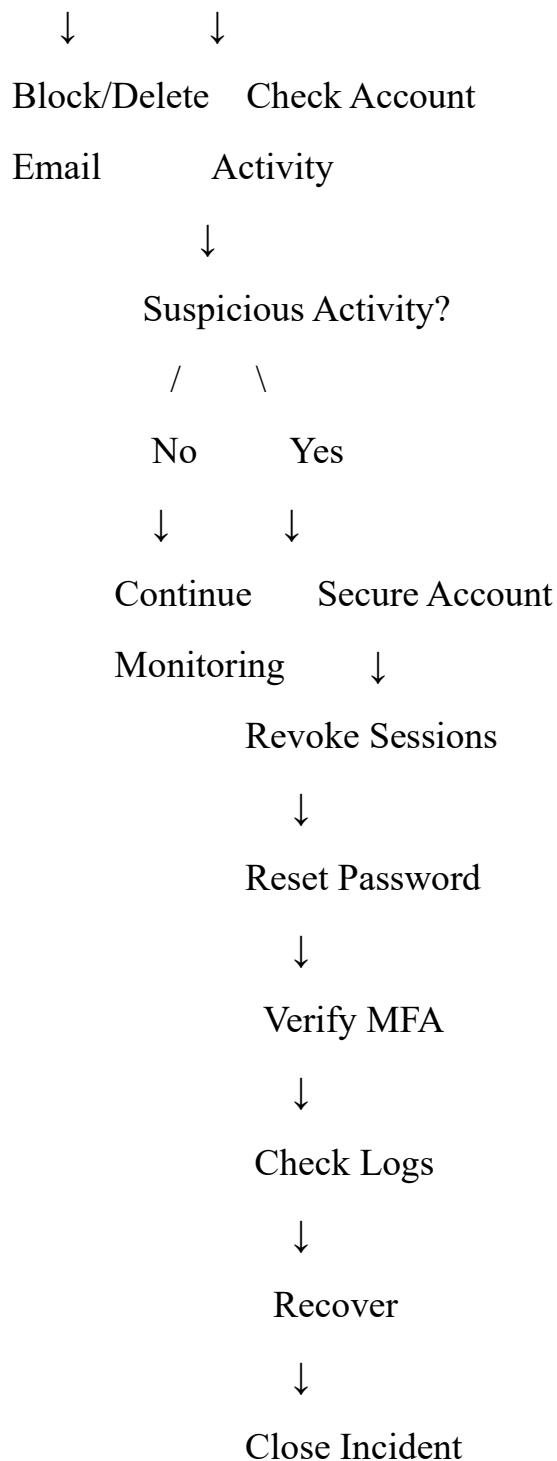


Did Employee Click the Link?

/ \

No

Yes



This process provides ABC Retail Solutions with a simple procedure to follow if an employee interacts with a phishing email.

7.18 Incident Response Metrics

The company can use a few basic measurements to check how well its incident response process is working.

Metric	Purpose
Mean Time to Detect (MTTD)	Shows how quickly an incident is detected
Mean Time to Respond (MTTR)	Shows how quickly the response begins
Mean Time to Recover	Shows how long it takes to restore normal operations
Number of Incidents	Shows how many incidents occurred
Phishing Reports	Shows how often employees report suspicious emails
Backup Recovery Success	Shows whether backups can be successfully restored
MFA Coverage	Shows how many important accounts use MFA

These measurements can be reviewed regularly to identify areas where the company's security process can be improved.

7.19 Incident Response Plan Summary

The Incident Response Plan gives ABC Retail Solutions a clear way to handle cybersecurity incidents. Instead of reacting without a plan, employees and the IT team can follow defined steps from the time an incident is detected until normal operations are restored.

The plan covers **preparation, detection, analysis, containment, eradication, recovery, and lessons learned**. Each stage plays an important role in controlling the incident and reducing its effect on the business.

The phishing scenario also shows how the plan can be applied to a realistic situation. By combining security monitoring, employee awareness, cybersecurity policies, and a proper response process, ABC Retail Solutions can be better prepared to deal with cyber incidents.

The next chapter will focus on the **practical incident simulation**, where the phishing scenario will be demonstrated using simulated events, logs, alerts, and an incident timeline.

CHAPTER 8

PRACTICAL INCIDENT SIMULATION

8.1 Introduction

The previous chapters covered the main security requirements of ABC Retail Solutions, including risk assessment, cybersecurity policies, vulnerability assessment, security monitoring, and incident response.

In this chapter, these concepts are brought together through a **practical incident simulation**. A phishing-related account compromise is used as the example because phishing was identified as one of the major risks in Chapter 3.

The purpose of this simulation is to understand what happens when a suspicious email leads to possible account compromise and how the organization should respond. The activity is carried out in a controlled environment using simulated emails, events, and logs. No real company, user account, or external system is targeted.

8.2 Purpose of the Simulation

The main purpose of the simulation is to show how a security incident can be detected and handled from beginning to end.

The simulation aims to:

- Show how a phishing incident can start.
- Demonstrate how an employee can report a suspicious message.
- Analyze simulated login and network activity.
- Identify suspicious behavior through security monitoring.
- Generate an alert based on unusual activity.
- Investigate the affected account.
- Demonstrate containment and recovery.
- Document the incident properly.
- Identify lessons that can be used to improve security.

8.3 Simulation Environment

A small and controlled lab environment is used for the demonstration. The environment represents the type of setup that could be used by ABC Retail Solutions for security monitoring.

Component	Purpose
Test Client	Represents an employee computer
Monitoring Machine	Used for security monitoring and analysis
Zeek	Used to observe network activity
Elasticsearch	Stores collected logs
Logstash	Processes and forwards logs
Kibana	Used to search logs and create dashboards
Simulated Email	Represents the phishing message
Simulated Logs	Used to demonstrate suspicious activity

The entire setup is used only for educational purposes.

8.4 Simulation Scenario

The simulation begins when an employee receives an email that appears to be from a trusted online service. The email asks the employee to verify their account by clicking a link.

The employee interacts with the link in the simulated environment. For the purpose of the project, it is assumed that the employee's credentials may have been exposed.

A short time later, several failed login attempts followed by a successful login appear in the simulated logs. This activity is considered suspicious and is reported for investigation.

The scenario is completely simulated. No real credentials are collected and no real phishing attack is carried out.

8.5 Incident Timeline

The simulated incident follows the timeline below:

Time Event

09:55 Employee receives simulated phishing email

10:02 Employee interacts with the simulated link

10:03 Credentials are considered potentially exposed

10:05 Several failed login attempts appear in the logs

10:06 A successful login follows the failed attempts

10:07 Monitoring identifies suspicious activity

10:10 Incident is reported to the IT Administrator

10:12 Affected account is temporarily secured

10:15 Active sessions are revoked

10:20 Password is reset

10:25 MFA status is checked

10:35 Related logs are reviewed

11:00 Account access is restored after verification

11:30 Incident report is completed

This timeline gives a simple picture of how an incident can move from detection to resolution.

8.6 Step 1 – Phishing Email Simulation

The first part of the simulation is a harmless example of a phishing email.

The simulated email contains some common warning signs, such as:

- An urgent request.
- A suspicious-looking link.
- A request to verify an account.
- A sender address that does not match the expected organization.
- Language designed to encourage the employee to act quickly.

For safety, the link used in the demonstration should point only to a **local training page or dummy page**.

Figure 8.2: Simulated Phishing Email

[Insert screenshot of your simulated phishing email here]

Description:

The figure shows a simulated phishing email created for educational purposes. It demonstrates some common signs that employees should look for when checking suspicious messages. No real credentials are collected during the simulation.

8.7 Step 2 – Employee Reporting

After noticing that the message appears suspicious, the employee reports it to the IT Administrator.

The employee provides basic information such as:

- When the email was received.
- Who appeared to send it.
- What happened after interacting with the link.
- Whether any information was entered.
- Which device was being used.
- Whether anything unusual was noticed afterward.

Reporting the incident quickly gives the IT team a better chance of preventing further problems.

Figure 8.3: Incident Report

[Insert screenshot of your incident report here]

Example:

Incident ID: INC-001

Reported By: Employee

Incident Type: Suspected Phishing

Affected System: Test Client

Affected Account: employee01

Severity: High

Status: Under Investigation

8.8 Step 3 – Log Analysis

After the incident is reported, the available logs are checked for unusual activity.

The following simulated login records are used:

Time	User	Event Result	Source
10:05	employee01	Login Failed	Test-IP-01
10:05	employee01	Login Failed	Test-IP-01
10:06	employee01	Login Failed	Test-IP-01
10:06	employee01	Login Failed	Test-IP-01
10:06	employee01	Login Failed	Test-IP-01
10:06	employee01	Login Successful	Test-IP-01

The five failed attempts followed by a successful login make the activity worth investigating.

The IT Administrator checks whether the employee recognizes the activity and also looks at other events that occurred around the same time.

Figure 8.4: Simulated Login Logs

[Insert screenshot of your log results or Kibana search here]

8.9 Step 4 – Security Alert

A simple monitoring rule is used to identify repeated failed login attempts.

The simulated rule is:

IF

5 or more failed login attempts

occur within 10 minutes

THEN

Generate a security alert

The purpose of this rule is to bring unusual login activity to the attention of the IT or security team.

The alert itself does not prove that the account has been compromised. It simply tells the team that the activity should be investigated.

Figure 8.5: Security Alert

[Insert screenshot of your alert or simulated alert here]

8.10 Step 5 – Investigation

The IT Administrator then investigates the suspicious activity.

The investigation focuses on:

- The affected user account.
- The number of failed login attempts.
- The successful login.
- The source information.
- Related network activity.
- Other events around the same time.
- Whether the employee recognizes the activity.

The investigation connects the suspicious login activity with the earlier simulated phishing event. Because of this connection, the account is treated as potentially compromised.

8.11 Step 6 – Containment

Once the account is considered potentially compromised, the next priority is to prevent further unauthorized access.

The following containment steps are used in the simulation:

1. Temporarily secure the affected account.
2. Revoke active sessions.
3. Reset the account password.
4. Verify MFA.

5. Review recent account activity.
6. Check for other suspicious activity.

The goal of containment is to stop the suspected compromise from continuing while the investigation is taking place.

Figure 8.6: Account Containment

[Insert screenshot of account being secured/disabled in your lab here]

8.12 Step 7 – Eradication

After containment, the possible causes of the incident are addressed.

For this simulation, the following actions are considered:

- Remove the simulated phishing message.
- Reset potentially exposed credentials.
- Check the affected device for suspicious activity.
- Make sure security software is active.
- Apply available security updates.
- Review account permissions.
- Look for other signs of compromise.

No real malware is introduced into the lab during this exercise.

8.13 Step 8 – Recovery

Once the investigation is completed and the account has been secured, normal access can be restored.

The recovery process includes:

- Confirming that the account is secure.
- Confirming that the password has been changed.
- Verifying MFA.
- Restoring access to required services.
- Checking the affected device.
- Continuing to monitor the account.

The account should only be restored after the IT Administrator has confirmed that the immediate security risk has been addressed.

8.14 Step 9 – Post-Incident Monitoring

Monitoring does not stop immediately after the account has been restored. The account and related systems should continue to be monitored for unusual activity.

The security team can look for:

- New failed login attempts.
- Unexpected successful logins.
- Changes to account settings.
- Unusual network connections.
- Attempts to access sensitive resources.
- Other activity associated with the affected account.

This helps make sure that the incident has actually been resolved.

8.15 Incident Investigation Summary

The complete simulation can be summarized as follows:

Phishing Email



Employee Interaction



Possible Credential Exposure



Multiple Failed Logins



Successful Login



Security Alert



Investigation



Account Containment



Password Reset + MFA Check



Log Review



Recovery



Post-Incident Monitoring



Incident Closed

This shows how the different parts of the project work together during an incident.

8.16 Incident Report

After completing the investigation, an incident report is prepared.

Field	Details
Incident ID	INC-001
Incident Type	Suspected Phishing / Account Compromise
Severity	High
Detection Method	Employee Report + Security Monitoring
Affected User	employee01
Affected System	Test Client
Initial Cause	Simulated Phishing Email
Containment	Account secured and sessions revoked

Field	Details
Eradication	Credentials reset and system checked
Recovery	Account restored after verification
Status	Closed
Evidence	Simulated email and logs

The report provides a record of the incident and makes it easier to understand what happened and how it was handled.

8.17 Lessons Learned

The simulation shows that a phishing email can potentially become a much bigger problem if an employee interacts with it and the account is later misused.

Some important lessons from the simulation are:

- Employees need regular phishing awareness training.
- Suspicious emails should be reported as soon as possible.
- MFA provides an additional layer of account protection.
- Login monitoring can help identify unusual activity.
- Important logs should be retained for investigations.
- Employees should know exactly who to contact when they notice a security problem.
- Incident response procedures should be tested regularly.
- Security policies should be updated based on lessons learned.

8.18 Practical Results

The simulation demonstrates how a suspected account-compromise incident can be handled from beginning to end.

The different parts of the project are connected in the following way:

Cybersecurity Policy → Risk Assessment → Vulnerability Assessment → Security Monitoring → Alert → Investigation → Incident Response → Recovery

This shows that cybersecurity does not depend on a single tool. A stronger security environment comes from combining technical controls, clear policies, employee awareness, monitoring, and a proper incident response process.

8.19 Chapter Summary

This chapter demonstrated a safe and controlled simulation of a phishing-related security incident involving ABC Retail Solutions.

The scenario started with a simulated phishing email and continued through suspicious login activity, detection, investigation, containment, recovery, and post-incident monitoring.

The exercise also showed how **Zeek and the ELK Stack** can support the monitoring and investigation process. The Incident Response Plan developed in Chapter 7 was then applied to the simulated situation.

Overall, the simulation shows how ABC Retail Solutions can move from simply identifying cybersecurity risks to actively detecting and responding to them. The results also highlight the importance of employee awareness, MFA, logging, monitoring, and regular testing of the incident response process.

The next chapter focuses on **Security Improvements and Recommendations**, where the proposed security controls will be reviewed and compared with the organization's earlier security position.

CHAPTER 9

SECURITY IMPROVEMENTS AND RECOMMENDATIONS

9.1 Introduction

The previous chapters helped identify the main cybersecurity risks and weaknesses in ABC Retail Solutions. The project also showed how a phishing-related incident could be detected, investigated, and handled using security monitoring and an incident response plan.

However, cybersecurity is not something that can be improved once and then forgotten. New threats can appear, software can become outdated, and the company's systems can change over time. Because of this, security measures need to be reviewed and improved regularly.

This chapter presents the main improvements recommended for ABC Retail Solutions. These recommendations are based on the risks and vulnerabilities identified during the project.

9.2 Recommended Security Improvements

Based on the assessment, ABC Retail Solutions should focus on the following areas:

- Stronger authentication.
- Better control over user access.
- Regular software updates.
- Improved network security.
- Reliable backups.
- Centralized logging and monitoring.
- Regular employee cybersecurity training.
- Periodic vulnerability assessments.
- Regular testing of the Incident Response Plan.

These improvements can help reduce the chances of a successful cyberattack and make it easier for the company to respond if an incident occurs.

9.3 Multi-Factor Authentication

One of the most useful improvements for the company would be implementing **Multi-Factor Authentication (MFA)**.

Passwords can sometimes be stolen through phishing or other attacks. MFA adds another verification step, making it harder for someone to access an account even if they know the password.

ABC Retail Solutions should enable MFA for:

- Email accounts.
- Cloud storage accounts.
- Administrator accounts.
- Remote access services.
- Important business applications.

The company should aim to have MFA enabled on all important accounts.

9.4 Improved Password Security

The company should also improve the way passwords are created and managed.

The recommended practices include:

- Using strong passwords.
- Avoiding password reuse.
- Using a trusted password manager.
- Changing passwords when an account may have been compromised.
- Avoiding shared accounts.
- Using MFA along with passwords.

Employees should also be made aware of why these rules are important. Simply having a password policy is not enough if employees do not understand how to follow it.

9.5 Improved Access Control

ABC Retail Solutions should regularly check who has access to its systems and information.

The company should:

- Give employees only the permissions they need.
- Keep administrator privileges limited.
- Use separate administrator accounts where appropriate.
- Review permissions regularly.
- Remove access when an employee leaves the organization.
- Disable unused accounts.
- Monitor access to sensitive information.

Following the **principle of least privilege** can help reduce the impact of a compromised account.

9.6 Network Security Improvements

The company network should also be properly secured because it connects employees to important systems and services.

Recommended improvements include:

- Using a properly configured firewall.
- Securing the company Wi-Fi.
- Changing default passwords on network devices.
- Using strong wireless security.
- Keeping network devices updated.
- Separating guest Wi-Fi from the internal network.
- Blocking unnecessary network services.
- Monitoring unusual network activity.

Tools such as **Zeek** can also be used to provide more information about network activity and help identify unusual patterns.

9.7 Endpoint Security

Employee computers are one of the main points where a cyberattack could enter the organization. Therefore, they should be protected properly.

ABC Retail Solutions should:

- Install and maintain endpoint protection.
- Keep operating systems updated.
- Apply security patches regularly.
- Enable firewalls where appropriate.
- Prevent unauthorized software installation.
- Lock computers when they are left unattended.
- Regularly check devices for security issues.
- Have a clear process for reporting lost or stolen devices.

These steps can help reduce the risk of malware infections and unauthorized access.

9.8 Backup and Recovery Improvements

Backups are especially important when dealing with ransomware, accidental deletion, hardware failure, or other situations that can cause data loss.

The company should:

- Back up important information regularly.
- Keep multiple copies of important data.
- Store at least one backup separately from the main network.
- Limit access to backup systems.
- Test backup restoration regularly.
- Keep records of backup activities.
- Review the backup process from time to time.

The company should continue to follow the **3-2-1 backup approach** wherever practical.

It is also important to remember that simply creating a backup does not guarantee that it will work when needed. The company should regularly test whether the data can actually be restored.

9.9 Centralized Logging and Monitoring

One of the weaknesses identified during the project was limited security logging. Improving this area can help the company notice suspicious activity earlier.

A centralized monitoring setup could work like this:

System Logs

+

Network Logs

+

Firewall Logs

+

Authentication Logs

↓

Logstash

↓

Elasticsearch

↓

Kibana

↓

Security Dashboard

This allows important events from different systems to be collected and viewed in one place.

The company can create alerts for events such as:

- Multiple failed login attempts.
- Suspicious successful logins.
- Unusual network activity.
- Repeated access attempts.
- Unexpected changes to important accounts.

9.10 Employee Cybersecurity Training

The practical simulation showed that employees have an important role in protecting the organization. A well-designed technical security system can still be affected if an employee accidentally clicks a suspicious link or shares sensitive information.

ABC Retail Solutions should provide regular training on:

- Phishing.
- Social engineering.
- Password security.
- MFA.
- Safe email usage.
- Safe internet browsing.
- Data protection.
- Incident reporting.
- Safe use of company devices.

The company can also conduct harmless simulated phishing exercises to help employees recognize suspicious messages.

The purpose of training should be to improve awareness rather than punish employees for making mistakes. Employees should feel comfortable reporting suspicious activity as soon as they notice it.

9.11 Regular Vulnerability Assessments

A vulnerability assessment should not be treated as a one-time activity. New vulnerabilities can appear whenever software, devices, or systems are changed.

ABC Retail Solutions should regularly:

1. Identify its assets.
2. Check for vulnerabilities.
3. Assess the associated risks.
4. Prioritize important vulnerabilities.
5. Fix the vulnerabilities.

6. Verify that the fixes worked.
7. Repeat the process.

This will help the company maintain a better security posture over time.

9.12 Incident Response Improvements

The Incident Response Plan created in Chapter 7 should also be tested regularly.

ABC Retail Solutions should:

- Keep the incident response plan updated.
- Maintain an updated contact list.
- Clearly assign responsibilities.
- Conduct tabletop exercises.
- Practice different incident scenarios.
- Review previous incidents.
- Maintain proper incident records.
- Update the plan when the company's systems change.

Regular practice can help employees respond more confidently during an actual security incident.

9.13 Security Metrics

The company can use a few simple metrics to check whether its security is improving.

Metric	Target
MFA Coverage	100% of important accounts
Backup Success Rate	More than 95%
Security Training Completion	100%
Critical Vulnerabilities	Fixed as a priority
Patch Compliance	More than 90%

Metric	Target
Phishing Reports	Increase over time
Incident Response Time	Continuously reduce

These measurements can be adjusted depending on the company's actual requirements and resources.

9.14 Before and After Comparison

The following table shows the difference between the company's earlier security situation and the proposed improvements:

Security Area	Before	After
Authentication	Mainly password-based	Password + MFA
Password Security	Basic rules	Strong password policy
Access Control	Limited review	Regular access reviews
Software Updates	Irregular	Regular patch management
Wi-Fi Security	Basic	Strong security + separate guest network
Backups	Limited testing	Regular backups + restore testing
Logging	Limited	Centralized logging
Monitoring	Mostly manual	Dashboard-based monitoring
Employee Training	Limited	Regular awareness training
Incident Response	Informal	Documented response plan
Vulnerability Assessment	Occasional	Regular assessment

The comparison shows that the proposed improvements cover both the **technical and human sides of cybersecurity**.

9.15 Recommended Security Roadmap

ABC Retail Solutions does not need to implement every improvement at the same time. A phased approach would be more practical for a small business.

Phase 1 – Immediate Improvements

The company should first focus on the most important security issues:

- Enable MFA.
- Strengthen password policies.
- Secure the Wi-Fi network.
- Update critical software.
- Review administrator accounts.
- Check important backups.

Phase 2 – Short-Term Improvements

After the immediate issues are addressed, the company can focus on:

- Regular employee cybersecurity training.
- Better endpoint protection.
- Regular vulnerability assessments.
- Regular access reviews.
- Centralized logging.

Phase 3 – Long-Term Improvements

The company can then work on:

- Improving security monitoring.
- Expanding the ELK dashboard.
- Conducting regular incident-response exercises.
- Reviewing cybersecurity policies.
- Tracking security metrics.
- Performing periodic security audits.

This approach allows the company to improve its security step by step without putting unnecessary pressure on its limited resources.

9.16 Overall Recommendations

Based on the complete project, the most important recommendations for ABC Retail Solutions are:

1. **Enable MFA** on important accounts.
2. **Use stronger password practices** and avoid password reuse.
3. **Provide regular employee training** on phishing and social engineering.
4. **Keep software and systems updated.**
5. **Review user permissions regularly.**
6. **Improve Wi-Fi and network security.**
7. **Maintain reliable and tested backups.**
8. **Centralize important security logs.**
9. **Use monitoring and alerts to identify suspicious activity.**
10. **Regularly test the Incident Response Plan.**
11. **Perform vulnerability assessments regularly.**
12. **Track security metrics to measure progress.**

9.17 Chapter Summary

This chapter presented the main security improvements recommended for ABC Retail Solutions based on the findings from the risk assessment, vulnerability assessment, monitoring process, and incident simulation.

The recommendations include both technical measures, such as MFA, endpoint protection, network security, backups, logging, and monitoring, and organizational measures, such as employee training, access control, vulnerability management, and incident response.

One of the main findings of this project is that cybersecurity is an ongoing process. Simply installing security software or creating a policy does not guarantee complete protection. The company needs to regularly review its systems, train its employees, check for vulnerabilities, monitor activity, and improve its response procedures.

By following the recommended security roadmap, ABC Retail Solutions can reduce its exposure to common cyber threats, improve its ability to detect suspicious activity, and respond more effectively when an incident occurs.

The next chapter will provide the **conclusion and future scope of the project**, summarizing the overall work, results, limitations, and possible improvements that can be made in the future.

CHAPTER 10

CONCLUSION AND FUTURE SCOPE

10.1 Introduction

This project was carried out to develop a practical cybersecurity framework for **ABC Retail Solutions**, a small business that depends on computers, networks, online accounts, customer information, and other digital systems for its daily work.

The project began by identifying the company's important assets and the risks associated with them. After that, possible vulnerabilities were identified and suitable cybersecurity policies were developed. Security monitoring using tools such as **Zeek and the ELK Stack** was also included to understand how unusual activity can be detected and investigated.

Finally, a simulated phishing incident was used to demonstrate how the company could handle a security problem from detection to recovery.

10.2 Project Outcome

The project brought together different areas of cybersecurity and created a security framework for ABC Retail Solutions.

The main areas covered in the project were:

- Asset identification.
- Risk assessment.
- Vulnerability assessment.
- Cybersecurity policies.
- Password and access control.
- Email and phishing protection.
- Data protection.
- Device and network security.
- Backup and recovery.
- Security monitoring.
- Log analysis.

- Incident response.
- Practical incident simulation.
- Security improvements and recommendations.

Together, these areas provide the company with a structured way of protecting its systems and responding to possible security problems.

10.3 Key Findings

During the project, several important security issues were identified.

One of the major risks was **phishing**. Employees can easily become targets through fake emails and messages, and a compromised account could potentially give an attacker access to company resources.

Another important issue was account security. Weak passwords and the absence of MFA can make it easier for attackers to gain unauthorized access. Using strong passwords together with MFA can provide better protection.

The assessment also highlighted other areas that need attention, including outdated software, excessive user permissions, insecure network settings, limited logging, and insufficient backup testing.

The project showed that monitoring is also important because logs can provide useful information about what happened during suspicious activity and can support an investigation.

10.4 Results of the Incident Simulation

The practical phishing simulation helped connect the different parts of the project.

The simulated incident followed this process:

Phishing Email



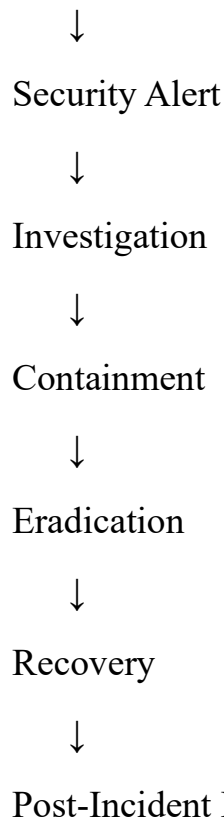
Employee Interaction



Possible Credential Exposure



Suspicious Login Activity



The simulation showed that dealing with a cyber incident involves more than simply removing a suspicious email. The organization needs to identify what happened, secure affected accounts or devices, investigate the activity, and make sure the problem does not continue.

10.5 Role of Security Monitoring

The project also demonstrated the importance of security monitoring.

Zeek can be used to observe network activity and generate useful network logs. The **ELK Stack** can then be used to collect, store, search, and visualize logs.

A monitoring dashboard can help the IT team notice events such as:

- Repeated failed login attempts.
- Unexpected successful logins.
- Unusual network connections.
- Suspicious activity from a device.
- Other events that may need investigation.

However, monitoring alone cannot provide complete protection. It works best when combined with strong security policies, employee awareness, access controls, backups, and an incident response plan.

10.6 Benefits for ABC Retail Solutions

The proposed cybersecurity framework can provide several benefits to the company.

Better Account Protection

Strong passwords and MFA can reduce the chances of unauthorized access to important accounts.

Better Employee Awareness

Regular training can help employees recognize phishing emails, suspicious links, and social engineering attempts.

Faster Detection

Security monitoring and centralized logs can help the company identify unusual activity more quickly.

Better Incident Handling

The Incident Response Plan gives employees and the IT team clear steps to follow when a security problem occurs.

Better Data Recovery

Regular and tested backups can help the company recover important information after data loss or ransomware.

Improved Overall Security

Combining policies, technical controls, monitoring, and employee awareness gives the company a stronger overall security structure.

10.7 Project Limitations

There are some limitations to this project.

- ABC Retail Solutions is a fictional company created for academic purposes.
- The phishing incident was simulated and was not a real cyberattack.

- No real company systems or user accounts were tested.
- The simulated logs do not represent the full complexity of logs from a real organization.
- The monitoring and detection rules were created mainly for demonstration purposes.
- The project was carried out in a limited lab environment.

Because of these limitations, the project should be considered a demonstration of how a small business could build and improve its cybersecurity process rather than a complete implementation for a real organization.

10.8 Future Scope

There are several ways this project could be developed further in the future.

1. Advanced SIEM

The monitoring system could be expanded by connecting more sources and creating more advanced detection rules.

2. Endpoint Monitoring

Endpoint monitoring could be added to detect suspicious processes, malware, and unusual activity on employee computers.

3. Automated Alerts

The system could be configured to automatically notify the IT or security team when important security events are detected.

4. More Incident Scenarios

Other incidents could be simulated, such as:

- Ransomware.
- Malware infection.
- Unauthorized access.
- Data leakage.
- Lost or stolen devices.
- Suspicious network activity.

5. Threat Intelligence

Threat intelligence could be added to provide more information about suspicious indicators and known threats.

6. Regular Phishing Tests

The company could conduct safe phishing-awareness exercises to check whether employees can identify suspicious messages.

7. Automated Vulnerability Scanning

Vulnerability scanning tools could be introduced to regularly check systems for known security weaknesses.

8. Network Segmentation

The network could be divided into separate sections for employees, guests, servers, and sensitive systems. This could help prevent an incident from spreading across the entire network.

10.9 Overall Conclusion

The main aim of this project was to develop a practical cybersecurity policy and incident response framework for a small business. This was achieved by combining **risk assessment, vulnerability assessment, security policies, security monitoring, incident response, and practical simulation.**

The project showed that even a small business can face several cybersecurity risks. Threats such as phishing, password attacks, malware, unauthorized access, and data theft can affect both business operations and sensitive information.

It also became clear that cybersecurity does not depend on just one tool. A company needs a combination of **technology, policies, employee awareness, monitoring, backups, and proper response procedures.**

For ABC Retail Solutions, following the recommendations made in this project can help reduce security risks and improve its ability to detect and respond to incidents.

The most important lesson from the project is that **being prepared is just as important as trying to prevent an attack.** No organization can guarantee that it will never face a cyber incident, but having proper security measures and a clear

response plan can reduce the damage and help the business recover more effectively.

10.10 Final Project Summary

The complete approach developed in this project can be summarized as:

Identify Assets



Assess Risks



Find Vulnerabilities



Create Security Policies



Implement Security Controls



Monitor Systems



Detect Suspicious Activity



Respond to Incident



Recover Systems



Learn and Improve

This process can be repeated regularly so that ABC Retail Solutions can continue improving its cybersecurity as its systems, employees, and business requirements change.